

Sprint 1 — Work Summary

TOTP 2FA

TOTP 2FA — Scopo e Ambito

Abbiamo definito e iniziato l'implementazione di un sistema di autenticazione a due fattori (2FA) basato su TOTP. Il design copre backend, frontend, comportamento di database e operazioni per secret handling deterministico, enforcement basato sui ruoli e lockout policy.



2FA — Decisioni Architetturali

Login in due step

Prima password, poi richiesta OTP con challenge bound all'utente.

Secrets e recovery codes

Derivati **deterministicamente** tramite HMAC master key + salt.

Lockout policy

Lockout dopo N tentativi falliti con blocco di 60s.

Enforcement configurabile

Enforcement configurabile per ruoli.

Nessun secret persistito

Nessun secret persistito direttamente.

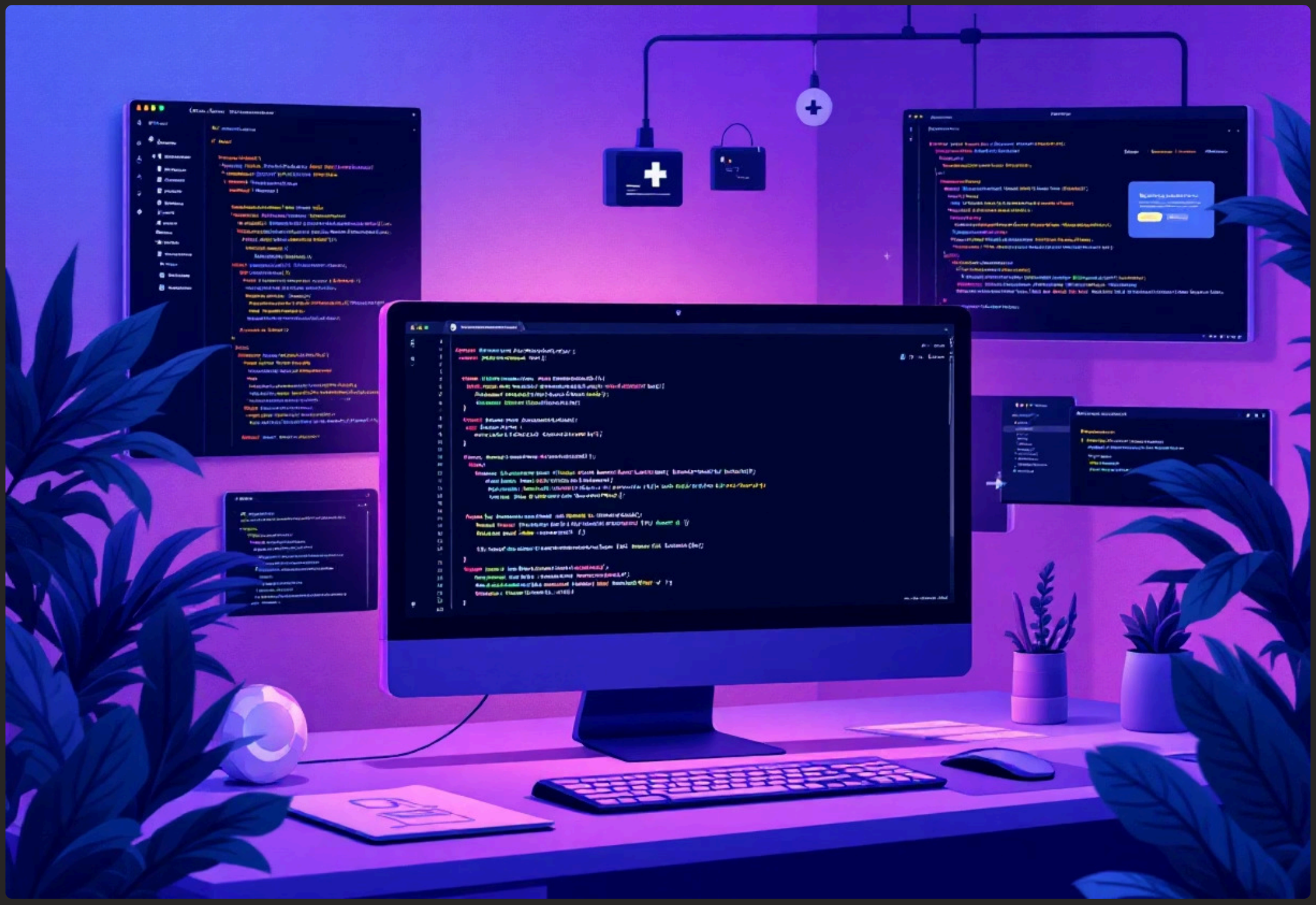
Modifiche al modello dati

Modifiche al modello dati utente (`twoFaVersionOrSalt`, `otpFailedAttempts`, etc.).

2FA — Prompt di Implementazione

Sono stati creati i prompt Codex per:

- Migrazioni DB per 2FA,
- Utility HMAC per TOTP e recovery codes,
- Endpoint di enrollment e conferma,
- Modifiche a `/login`,
- Endpoint di verifica OTP/recovery e JWT issuance,
- Enforcement ruoli, UX frontend OTP/recovery, test lockout/recovery, documentazione e bootstrap DB/CI.



2FA — Definition of Done

- [ ] **Nessun secret persistito**

  Nessun secret persistito,

- [ ] **JWT rilasciato solo dopo OTP/recovery**

  JWT rilasciato solo dopo OTP/recovery,

- [ ] **Lockout e jump-ahead recovery**

  Lockout e jump-ahead recovery correttamente gestiti,

- [ ] **Documenti e configurazioni**

  Documenti e configurazioni operazionali aggiornati,

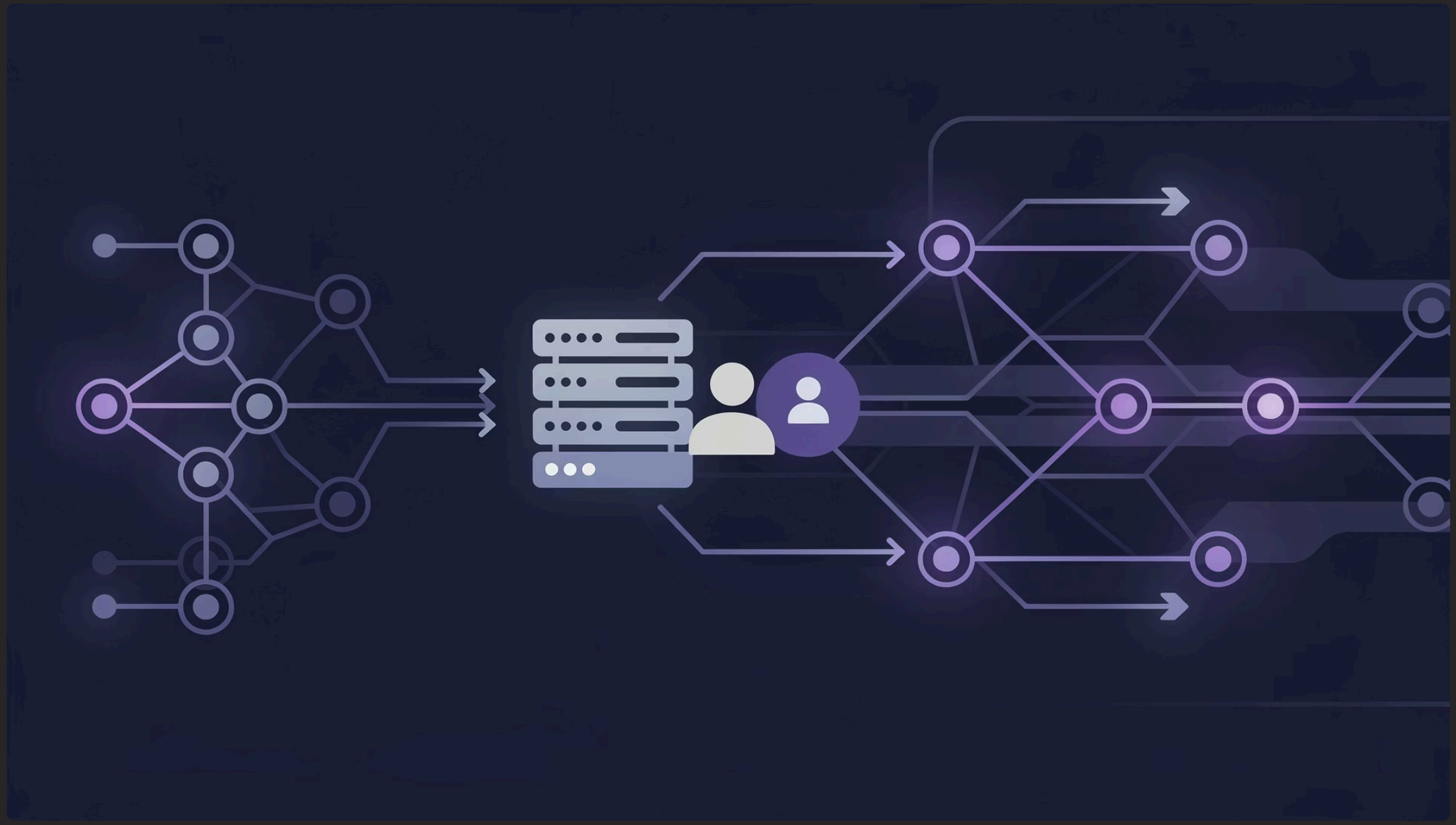
- [ ] **Test automatizzati**

  Test automatizzati su lockout e recovery edge cases.

Logout

Logout — Goal

Introduzione di un meccanismo di logout robusto con invalidamento JWT server-side tramite blacklist condivisa su tutti i tenant.



Logout — Backend Changes

01

Nuova entità BlacklistedToken

Nuova entità `BlacklistedToken` mappata su tabella `blacklisted_tokens`.

02

JwtBlacklistService

`JwtBlacklistService` per persistere e validare token invalidati.

03

Integrazione con LogoutController

Integrazione con `LogoutController`, JWT filter aggiornata per bloccare token in blacklist.

04

Clock condiviso

`Clock` condiviso per timestamp deterministici nei test.

Logout — Test



I test coprono l'intero flusso: login → logout → accesso a risorsa protetta. Verificano che i JWT invalidati siano effettivamente rifiutati.

Logout — Deployment & Risk

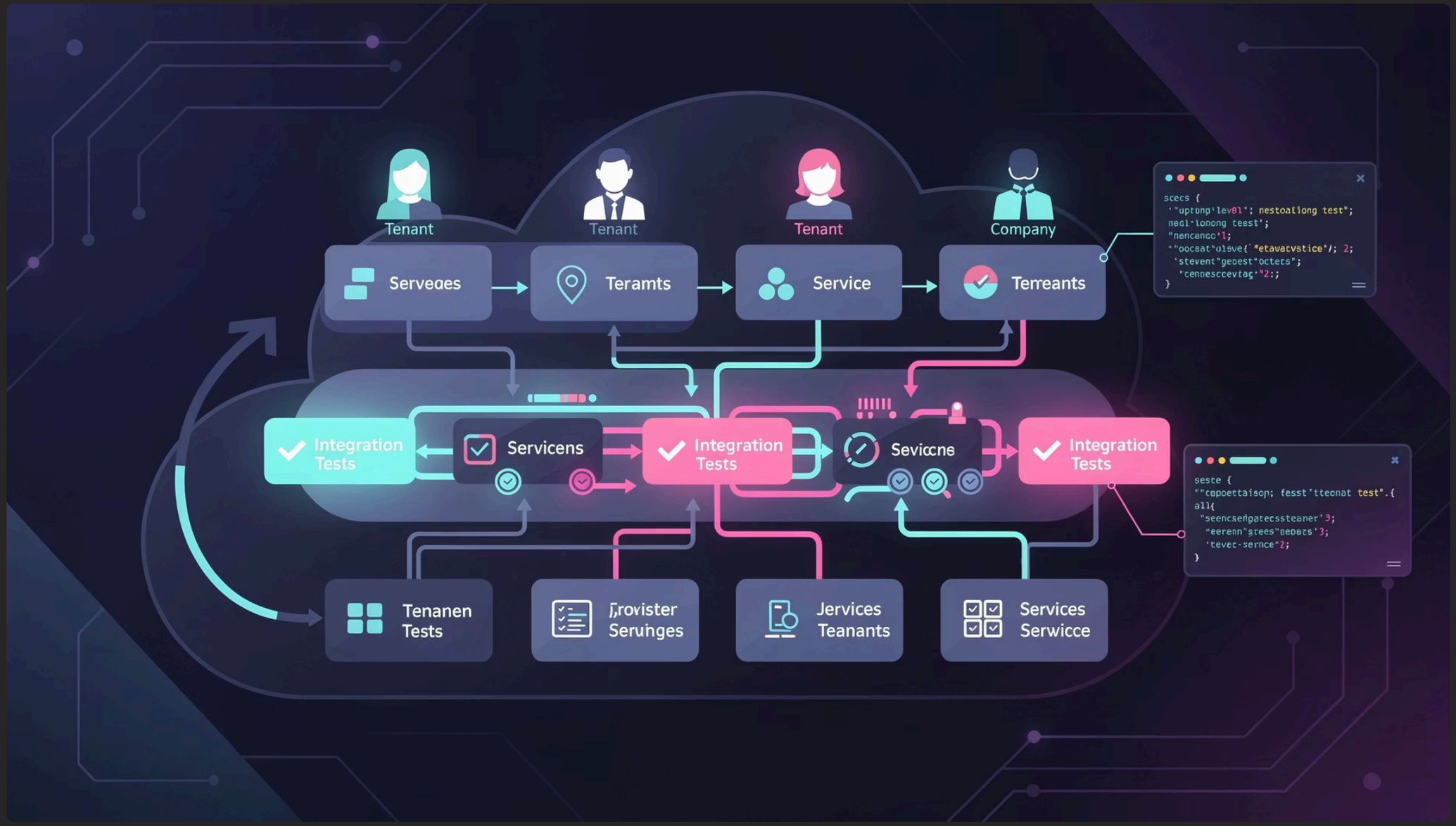
La blacklist è nella schema `public`; i permessi tenant devono consentire insert/read. Rischi: crescita tabella blacklist.

> **Attenzione:** Monitorare la crescita della tabella blacklist e implementare strategie di retention per evitare problemi di performance.

Test Cases Revival

Test Case — Focus

L'attività ha mirato a sistemare i test di integrazione per i moduli **Schedule** e **Scocciatura**, centralizzando la risoluzione multitenant dello schema tramite `AbstractMultiTenantIntegrationTest`.



Test Case — Risultati

Test operativi

Le classi di test per Schedule e Scocciatura sono quasi completamente operative.

Fix implementati

Fix minori implementati per allinearle allo stato corrente del sistema.

Test Case — Rimanenti

Test funzionanti

Alcuni test nel sottopackage `/control` sono già funzionanti:

- `changePassword`
- `giustificaForzatura`
- `calendarService`

Test in attesa

Altri rimangono commentati e in attesa di decisioni progettuali:

- servizi
- turni
- utente
- vincoli

Sprint 1 — Conclusioni

Sprint 1 ha prodotto: design e prime implementazioni per 2FA TOTP, un meccanismo di logout con blacklist JWT e significativi progressi sull'infrastruttura di test. Restano aperte attività di refactoring test e ottimizzazione blacklist retention/ops.





Grazie dell'attenzione

~CoffeeBreakpoint Team